02

IDEASPROPIAS
editorial

Establecimiento de protocolos de seguridad

1. Introducción a los protocolos de seguridad
2. Explotación automática de vulnerabilidades
3. Explotación manual de vulnerabilidades
4. Enumeración básica de una web
    4.1. Fuzzing web
5. Explotación básica de vulnerabilidades web
    5.1. Explotación básica con inyecciones SQL
    5.2. Explotación automática con inyecciones SQL
    5.3. Obtención de una webshell de forma automática
    5.4. Obtención de una webshell de forma manual

No está permitida la reproducción total o parcial de este curso, ni su tratamiento informático, ni la transmisión de ninguna forma o por cualquier medio, ya sea electrónico, mecánico, por fotocopia, por registro u otros métodos, sin el permiso previo y por escrito de los titulares del Copyright.

DERECHOS RESERVADOS 2024, por © Ideaspropias Editorial.

1. Introducción a los protocolos de seguridad

Comprender los **protocolos de red** es esencial antes de iniciar cualquier actividad de hacking web, ya que estos protocolos definen las reglas y procedimientos que rigen la comunicación entre los dispositivos y los sistemas en una red. Sin un entendimiento claro de cómo funcionan estos protocolos, es imposible identificar las posibles vulnerabilidades o fallos de seguridad que pueden ser explotados.

Algunos de los protocolos más importantes en el contexto del hacking web son:

Protocolos HTTP, HTTPS y DNS

Como ya sabes, en el contexto de la ciberseguridad y hacking web, la comprensión de los protocolos HTTP, HTTPS y DNS resulta fundamental, sobre todo a la hora de hacer una buena enumeración web, ya sea identificando subdominios, directorios u otros componentes visibles de una web.

Durante este proceso, se puede descubrir información valiosa, como configuraciones erróneas, servicios expuestos o recursos olvidados, que pueden ser el punto de partida para explotar vulnerabilidades.

No está permitida la reproducción total o parcial de este curso, ni su tratamiento informático, ni la transmisión de ninguna forma o por cualquier medio, ya sea electrónico, mecánico, por fotocopia, por registro u otros métodos, sin el permiso previo y por escrito de los titulares del Copyright.

DERECHOS RESERVADOS 2024, por © Ideaspropias Editorial.

Protocolos HTTP, HTTPS y DNS

Ahora bien, ¿sabrías distinguir entre los protocolos HTTP, HTTPS y DNS? Conoce en detalle la utilidad de cada uno con este vídeo de Mario Álvarez, cuyo tiempo de estudio es de 01:35.

Otros protocolos

Además de los protocolos de red mencionados, existen otros protocolos que sirven para funciones distintas, como la transferencia de archivos y la administración remota de sistemas, por ejemplo, los protocolos **FTP y SSH.**

- **FTP (*file transfer protocol*):** se utiliza para transferir archivos entre sistemas en una red, pero es un protocolo que transmite datos sin cifrado, lo que lo hace vulnerable a la interceptación y el robo de información. Para mejorar la seguridad, se recomienda utilizar SFTP *(secure file transfer protocol),* que cifra los datos durante la transferencia.

- **SSH (*secure shell*):** proporciona una manera segura de acceder y administrar sistemas remotos mediante una conexión cifrada. A diferencia de FTP, SSH está diseñado para ser seguro, pero aun así es crucial mantenerlo actualizado para protegerse contra posibles vulnerabilidades.

Es fundamental comprender y **mantener actualizados** todos los protocolos utilizados en un entorno de red, ya que los protocolos desactualizados pueden convertirse en puntos de entrada para atacantes.

Las vulnerabilidades en estos protocolos pueden ser descubiertas con el tiempo y los ataques dirigidos a protocolos obsoletos pueden hacer que un atacante consiga acceso remoto a nuestro servidor, tanto utilizando herramientas que explotan vulnerabilidades de forma automática, como el uso de *exploits* que puedan estar disponibles por Internet para hacer esta labor.

No está permitida la reproducción total o parcial de este curso, ni su tratamiento informático, ni la transmisión de ninguna forma o por cualquier medio, ya sea electrónico, mecánico, por fotocopia, por registro u otros métodos, sin el permiso previo y por escrito de los titulares del Copyright.

DERECHOS RESERVADOS 2024, por © Ideaspropias Editorial.

2. Explotación automática de vulnerabilidades

La explotación automática de vulnerabilidades hace referencia al uso de herramientas especializadas que pueden identificar y explotar vulnerabilidades en sistemas y aplicaciones de manera automatizada. Dichas herramientas están diseñadas para simplificar y acelerar el proceso de explotación, permitiendo a las personas usuarias lanzar ataques sin necesidad de realizar manualmente todos los pasos involucrados en la identificación y explotación de vulnerabilidades.

Un ejemplo de herramienta para explotar vulnerabilidades de forma automática es **Metasploit,** que es una plataforma de código abierto utilizada para desarrollar, probar y ejecutar exploits contra sistemas informáticos vulnerables. Por ello, se utiliza para realizar pruebas de penetración y seguridad informática para identificar y corregir fallos de seguridad.

Explotación automática de vulnerabilidades

La manera más optima de llevar a cabo una explotación automática de vulnerabilidades es a través de un laboratorio de pruebas vulnerable desplegado, por ejemplo, en la plataforma de Dockerlabs. ¿Te gustaría descubrir cómo hacerlo? Mario Álvarez te lo explica en el siguiente vídeo, cuyo tiempo de estudio es de 05:21. ¡Adelante!

Es muy importante prestar atención a la **versión** de los servicios que corren en un puerto porque, si la versión es obsoleta, es muy probable que contenga vulnerabilidades conocidas. Estas vulnerabilidades pueden ser explotadas para comprometer la seguridad del sistema y acceder a él. Por lo tanto, mantener los servicios actualizados es una medida esencial para reducir el riesgo de ataques y asegurar la protección de la infraestructura.

El explorar cómo identificar y explotar debilidades en sistemas, nos ha servido para comprender mejor la seguridad informática y las técnicas utilizadas en pruebas de penetración. Un entorno controlado nos permitirá practicar de manera segura y ética, desarrollando habilidades esenciales para la protección de infraestructuras tecnológicas.

No está permitida la reproducción total o parcial de este curso, ni su tratamiento informático, ni la transmisión de ninguna forma o por cualquier medio, ya sea electrónico, mecánico, por fotocopia, por registro u otros métodos, sin el permiso previo y por escrito de los titulares del Copyright.

DERECHOS RESERVADOS 2024, por © Ideaspropias Editorial.

3. Explotación manual de vulnerabilidades

Es muy importante distinguir entre la **explotación manual** y **automática** de vulnerabilidades. ¿Te gustaría conocer qué las diferencia?

- **Explotación manual de vulnerabilidades:** implica que un usuario identifique una vulnerabilidad en un sistema y luego busque y pruebe exploits específicos de manera manual. Esto puede incluir la búsqueda en bases de datos de exploits en línea (como ExploitDB), descargando código o exploit de páginas como GitHub, y la adaptación de este a cada situación particular. Así, tenemos un alto grado de control y personalización de nuestros ataques. Sin embargo, el proceso es más lento y requiere un conocimiento técnico más avanzado.
- **Explotación automática de vulnerabilidades:** implica que se usen herramientas como Metasploit o SQLmap (entre otras) y permite que usuarios automaticen gran parte del proceso. Estas herramientas pueden escanear sistemas en busca de vulnerabilidades y luego aplicar automáticamente los exploits más adecuados, minimizando la necesidad de intervención manual. Aunque es más rápido y accesible para quienes tienen poca experiencia, puede ser menos preciso y adaptable, en comparación a la explotación manual.

Explotación manual de vulnerabilidades

¿Te gustaría descubrir cuáles son los pasos necesarios para encontrar, descargar y ejecutar exploits, analizando cómo funcionan y los riesgos asociados con su uso? ¡Presta atención a este vídeo de Mario Álvarez para descubrirlo!

Su tiempo de estudio es de 05:24.

Es muy importante revisar el **código de los exploits** creados por terceros antes de ejecutarlos, ya que podrían contener algún *malware* que comprometa nuestra seguridad. Para ello, podemos acceder al repositorio de GitHub del exploit en concreto y revisar su código, el cual, por lo general, suele estar hecho en Python. Esto implica tener conocimientos, básicos o intermedios, de dicho lenguaje de programación, para entender el código de manera aproximada y asegurarnos de que no tiene contenido malicioso. El ejecutar códigos sin que analizarlos previamente, podría exponernos a ser *hackeados,* por lo que siempre debemos verificar su integridad y origen.

No está permitida la reproducción total o parcial de este curso, ni su tratamiento informático, ni la transmisión de ninguna forma o por cualquier medio, ya sea electrónico, mecánico, por fotocopia, por registro u otros métodos, sin el permiso previo y por escrito de los titulares del Copyright.

DERECHOS RESERVADOS 2024, por © Ideaspropias Editorial.

4. Enumeración básica de una web

La **enumeración básica de una web** hace referencia al proceso de recopilar información general sobre un sitio web, con el objetivo de identificar posibles puntos de acceso o vulnerabilidades. Este proceso suele involucrar **dos elementos.** ¿Te imaginas cuáles podrían ser?

- **Herramientas automatizadas:** aquellas que escanean el servidor en busca de directorios ocultos, archivos con extensiones específicas (como .php, .txt, .bak).
- **Información sensible:** aquella que no debería estar expuesta públicamente, como configuraciones de seguridad o credenciales.

Al descubrir estos elementos, un atacante puede planear ataques más dirigidos o explotar vulnerabilidades específicas del servidor.

Herramientas

La enumeración se puede llevar a cabo mediante **herramientas** como Dirb, Gobuster o Wfuzz, porque permiten descubrir subdominios y rutas ocultas que no están listadas en la interfaz principal.

Estas herramientas ayudan a:

- Identificar recursos no evidentes.
- Encontrar puntos de entrada adicionales para pruebas de seguridad.
- Mapear la superficie de ataque de la web, revelando posibles vulnerabilidades.

No está permitida la reproducción total o parcial de este curso, ni su tratamiento informático, ni la transmisión de ninguna forma o por cualquier medio, ya sea electrónico, mecánico, por fotocopia, por registro u otros métodos, sin el permiso previo y por escrito de los titulares del Copyright.

DERECHOS RESERVADOS 2024, por © Ideaspropias Editorial.

4.1. Fuzzing web

La enumeración se encuentra estrechamente relacionada con el ***fuzzing* web,** que es una técnica más específica que utiliza una *wordlist* para probar múltiples combinaciones de posibles directorios, archivos y parámetros en el servidor.

El objetivo de esta técnica es descubrir **rutas ocultas, archivos no indexados o vulnerabilidades** que no son evidentes de primeras. Al combinar la enumeración con fuzzing web, se puede obtener una perspectiva más completa de las posibles debilidades de un sitio web, lo que facilita la identificación de puntos de acceso o información sensible expuesta.

No obstante, hay diversos **tipos de fuzzing web.**

- **Fuzzing de directorios web:** se basa en realizar búsquedas automáticas en un sitio web, enviando numerosas solicitudes HTTP, probando diferentes nombres de posibles directorios o archivos, con el objetivo de descubrir aquellos que existan en el servidor. Herramientas como **Gobuster** o **Dirb** permiten automatizar este proceso, probando listas de palabras comunes para descubrir rutas ocultas o sensibles en un servidor web, lo que ayuda a identificar posibles puntos de entrada no protegidos.

- **Fuzzing de archivos web:** permite encontrar archivos específicos en lugar de solo directorios usando, por ejemplo, el parámetro `-x` de **Gobuster.** Este parámetro permite buscar archivos con extensiones determinadas, como .php, .html, o .txt, ayudando a descubrir documentos sensibles o configuraciones importantes en el servidor web que podrían ser vulnerables.

- **Fuzzing de subdominios:** facilita encontrar subdominios en un servidor. Para ello, primero debes tener clara la diferencia entre un dominio y un subdominio:

    - **Dominio:** es la dirección principal de un sitio web en Internet. Está compuesto por un nombre y una extensión, como «ejemplo.com». Los dominios se utilizan para identificar de manera única a un sitio web en la red.

    - **Subdominio:** es una parte del dominio principal y se utiliza para organizar y separar diferentes secciones del sitio web. Por ejemplo, en la página «blog.ejemplo.com», «blog» es el subdominio de «ejemplo.com». Los subdominios permiten estructurar el contenido y crear áreas distintas dentro del mismo dominio principal.

  Algunas de las herramientas con las que puedes llevar a cabo el fuzzing de subdominios son **DNSDumpster** o **Wfuzz,** las cuales conocerás con detalle más adelante.

  Una vez identificado un subdominio dentro del servidor, es importante agregarlo al archivo `/etc/hosts` para que nuestro sistema lo reconozca y podamos interactuar con él correctamente.

No está permitida la reproducción total o parcial de este curso, ni su tratamiento informático, ni la transmisión de ninguna forma o por cualquier medio, ya sea electrónico, mecánico, por fotocopia, por registro u otros métodos, sin el permiso previo y por escrito de los titulares del Copyright.

DERECHOS RESERVADOS 2024, por © Ideaspropias Editorial.

DNSDumpster

DNSDumpster permite identificar subdominios asociados a un dominio principal y recopilar información de fuentes públicas, como registros DNS, para identificar subdominios existentes. Además, ofrece una forma pasiva de enumeración, ya que no interactúa directamente con el servidor objetivo, lo que lo hace menos intrusivo y rápido. Es ideal para obtener una lista inicial de subdominios sin generar tráfico en el dominio objetivo.

Enumeración de subdominios con DNSDumpster

¡Aprende ahora a identificar subdominios con DNSDumpster con el siguiente vídeo de Mario Álvarez, cuyo tiempo de estudio es de 02:47!

Wfuzz

Wfuzz permite realizar búsquedas exhaustivas para descubrir subdominios ocultos, principalmente en aquellos servidores donde pueda estar configurado un subdominio. Además, utiliza un enfoque activo para enumerar subdominios mediante un ataque de fuerza bruta. Esto es enviar solicitudes al servidor utilizando una lista de posibles subdominios (wordlist).

Aunque este método puede descubrir subdominios que no están listados en registros públicos, es más intrusivo y puede ser más lento, ya que depende del tamaño de la wordlist y la velocidad de respuesta del servidor.

Enumeración de Subdominios con Wfuzz

Llegados a este punto, ¿te gustaría aprender a enumerar subdominios con Wfuzz? ¡Presta atención al siguiente vídeo de Mario Álvarez!

Su tiempo de estudio es de 08:34.

No está permitida la reproducción total o parcial de este curso, ni su tratamiento informático, ni la transmisión de ninguna forma o por cualquier medio, ya sea electrónico, mecánico, por fotocopia, por registro u otros métodos, sin el permiso previo y por escrito de los titulares del Copyright.

DERECHOS RESERVADOS 2024, por © Ideaspropias Editorial.

5. Explotación básica de vulnerabilidades web

Una **vulnerabilidad web** es una debilidad o defecto en el diseño, implementación, configuración o gestión de una aplicación o sitio web que puede ser explotado por atacantes para realizar acciones no autorizadas como, por ejemplo, el robo de datos, la alteración de contenido, la interrupción de servicios, entre otras.

¿Te haces una idea de cuáles podrían ser algunas de las vulnerabilidades más comunes?

- **Filtración de información sensible:** puede ocurrir cuando una aplicación web expone datos confidenciales, ya sea a través de errores en el código, configuraciones inadecuadas o mensajes de error detallados. Los atacantes pueden detectar esta información mediante técnicas de fuzzing web, donde envían entradas inesperadas para descubrir puntos débiles.
- **Inyecciones SQL:** permite a un atacante insertar información SQL maliciosa en un formulario web para acceder o manipular datos en una base de datos, alterando así el correcto funcionamiento de la base de datos.
- ***Cross-site scripting* (XSS):** permite a un atacante inyectar información maliciosa en una página web con el objetivo de que termine siendo ejecutada en el navegador de otros usuarios, comprometiendo su información o identidad.
- **Ejecución remota de código:** permite a un atacante ejecutar comandos o programas en un servidor o sistema remoto sin autorización, lo que puede llevar al control total del sistema afectado.
- ***Webshell:*** proporciona acceso remoto a un atacante a través de un *script* malicioso cargado en el servidor, permitiéndole ejecutar comandos y explorar el entorno del servidor.

La explotación básica de vulnerabilidades web se puede llevar a cabo utilizando técnicas comunes, como **inyecciones SQL** o la creación de una **webshell.**

Estas técnicas son útiles para entender cómo los atacantes pueden comprometer sistemas y para fortalecer las medidas de seguridad en contra de tales amenazas.

No está permitida la reproducción total o parcial de este curso, ni su tratamiento informático, ni la transmisión de ninguna forma o por cualquier medio, ya sea electrónico, mecánico, por fotocopia, por registro u otros métodos, sin el permiso previo y por escrito de los titulares del Copyright.

DERECHOS RESERVADOS 2024, por © Ideaspropias Editorial.

5.1. Explotación básica con inyecciones SQL

Antes de profundizar en las inyecciones SQL, es importante entender cómo se estructuran y ejecutan las **consultas SQL,** ya que esto ayuda a comprender cómo un atacante puede manipularlas para introducir código malicioso. Al entender cómo se forman las consultas y cómo interactúan con la base de datos, se puede identificar de qué manera las inyecciones SQL comprometen la seguridad de una aplicación y cómo prevenirlas eficazmente.

En una **inyección SQL,** al introducir un código malicioso en campos de entrada, el atacante puede alterar la consulta original para acceder, modificar o eliminar datos no autorizados.

Explotación básica SQL injection

Ahora bien, ¿te animas a descubrir cómo puedes explotar una inyección SQL? ¡Mario Álvarez te lo explica en este vídeo, con un tiempo de estudio de 05:24!

Caso práctico: consulta e inyección SQL

Una pequeña empresa ha desarrollado una aplicación web para la gestión de usuarios. Esta aplicación permite a las personas administradoras iniciar sesión en un panel, donde pueden comprobar y gestionar la información de la plantilla de empleados. El sistema de autenticación se basa en una simple consulta SQL que valida el nombre de usuario y la contraseña.

El código del *backend* que realiza la autenticación es el siguiente:

```
SELECT * FROM usuarios WHERE nombre_usuario = '<NOMBRE_USUARIO>' AND
contrasena = '<CONTRASENA>';
```

¿Cómo podrías identificar la vulnerabilidad en la consulta SQL anterior y realizar una inyección SQL para acceder al sistema, sin necesidad de conocer las credenciales correctas?

Reflexiona sobre la cuestión planteada y descubre la solución.

Solución

Para identificar la vulnerabilidad, debemos utilizar `‘ or 1=1— —` para que la consulta se transforme en:

```
SELECT * FROM usuarios WHERE nombre_usuario = '' OR 1=1-- -' AND contrasena
= '<CONTRASENA>';
```

Como resultado, la consulta devuelve todos los registros de la tabla de usuarios, permitiendo el acceso al sistema.

No está permitida la reproducción total o parcial de este curso, ni su tratamiento informático, ni la transmisión de ninguna forma o por cualquier medio, ya sea electrónico, mecánico, por fotocopia, por registro u otros métodos, sin el permiso previo y por escrito de los titulares del Copyright.

DERECHOS RESERVADOS 2024, por © Ideaspropias Editorial.

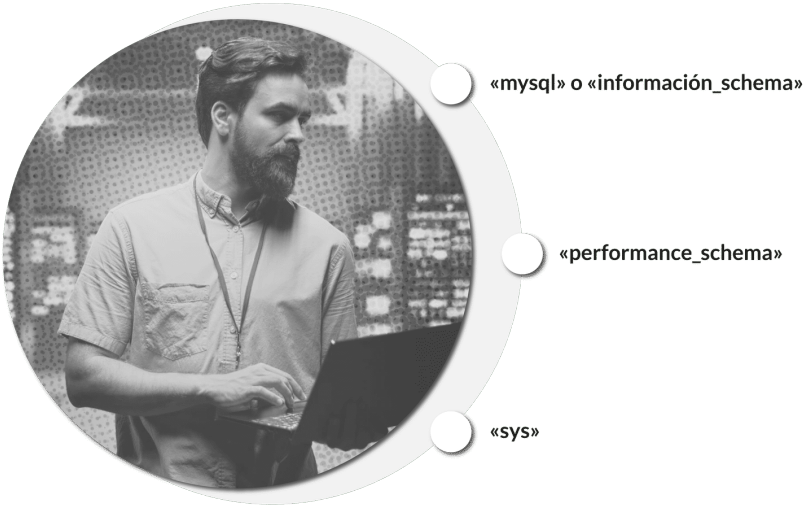
5.2. Explotación automática con inyecciones SQL

Si nos centramos en la explotación automática con inyecciones SQL, cabe destacar la herramienta de código abierto **SQLmap,** que viene instalada por defecto en Kali Linux y ofrece diversas funcionalidades, por ejemplo:

- Permite automatizar la detección y explotación de vulnerabilidades de inyección SQL en aplicaciones web.
- Permite a las personas usuarias identificar y explotar estos fallos de seguridad para obtener acceso a bases de datos, realizar extracciones de datos y ejecutar comandos arbitrarios en el servidor.
- Facilita el proceso al ofrecer funciones avanzadas como la automatización de la identificación de tipos de bases de datos y la obtención de datos sensibles con poco esfuerzo manual.

Bases de datos SQL

En muchos sistemas de gestión de bases de datos SQL, como MySQL, se crean varias **bases de datos** por defecto al instalar el software. ¿Te gustaría conocer algunas de ellas?



- **«mysql» o «información_schema»:** se utilizan para almacenar información sobre las bases de datos, usuarios y permisos.
- **«performance_schema»:** se usa para recopilar datos sobre el rendimiento del servidor de base de datos.
- **«sys»:** contiene vistas y funciones útiles para la administración y diagnóstico del sistema.

Es importante fijarse en que la base de datos creada manualmente tenga un **nombre diferente** a los nombres reservados. Al identificar un nombre único y distintivo para la base de datos creada por el usuario, se facilita la distinción entre las bases de datos del sistema y las creadas

No está permitida la reproducción total o parcial de este curso, ni su tratamiento informático, ni la transmisión de ninguna forma o por cualquier medio, ya sea electrónico, mecánico, por fotocopia, por registro u otros métodos, sin el permiso previo y por escrito de los titulares del Copyright.

DERECHOS RESERVADOS 2024, por © Ideaspropias Editorial.

explícitamente por el usuario, lo que ayuda a establecer nuestro objetivo de la base de datos que debamos enumerar.

SQLmap

Como ya sabes, SQLmal es una herramienta centrada en la explotación automática con inyecciones SQL, pero ¿sabes cómo funciona?

Explotación automática con SQLmap

Presta atención al siguiente vídeo, cuyo tiempo de estudio es de 05:23, y aprende a emplear la herramienta SQLmap para hacer explotaciones más automáticas a manos de Mario Álvarez. ¡Vamos!

5.3. Obtención de una webshell de forma automática

Una webshell que se obtiene de forma automática, solo ejecuta el comando que nos da acceso al servidor.

Un ejemplo de código malicioso es una webshell de **PentestMonkey,** ya que permite a un atacante ejecutar comandos en un servidor web comprometido, es decir, proporciona una webshell que ejecuta el comando que nos permite acceder al servidor de forma más directa. Esta webshell de PentestMonkey la podemos encontrar en GitHub, que es una plataforma de desarrollo colaborativo que permite a los desarrolladores almacenar, compartir y colaborar en proyectos. Además, es también ampliamente utilizada en la comunidad de ciberseguridad para compartir herramientas para explotar vulnerabilidades.

No está permitida la reproducción total o parcial de este curso, ni su tratamiento informático, ni la transmisión de ninguna forma o por cualquier medio, ya sea electrónico, mecánico, por fotocopia, por registro u otros métodos, sin el permiso previo y por escrito de los titulares del Copyright.

DERECHOS RESERVADOS 2024, por © Ideaspropias Editorial.

Creación automática de una webshell

¿Te animas a conocer el proceso de obtención de una webshell? En este vídeo, cuyo tiempo de estudio es de 06:46, Mario Álvarez te explica cómo realizarlo de forma automática, empleando un laboratorio de DockerLabs desde Kali Linux.

5.4. Obtención de una webshell de forma manual

Una webshell que se crea de forma manual permite ejecutar cualquier comando.

Creación manual de una webshell

¿Te imaginas cuál es el paso a paso a seguir para crear una webshell manualmente? ¡Presta atención a este vídeo de Mario Álvarez para descubrirlo!

Su tiempo de estudio es de 06:18.

URL encoding

En el vídeo se menciona el **URL *encoding,*** pero ¿sabrías explicar qué es y cuándo se lleva a cabo?

- **¿En qué consiste?**
  Consiste en convertir caracteres especiales en una cadena de caracteres que pueden ser enviados a través de la web.
- **¿Cuándo se lleva a cabo?**
  Se lleva a cabo cuando un navegador envía una conexión a un servidor y la información en la URL (como parámetros y comandos) necesita estar en un formato adecuado para ser interpretada correctamente por el servidor.

No está permitida la reproducción total o parcial de este curso, ni su tratamiento informático, ni la transmisión de ninguna forma o por cualquier medio, ya sea electrónico, mecánico, por fotocopia, por registro u otros métodos, sin el permiso previo y por escrito de los titulares del Copyright.

DERECHOS RESERVADOS 2024, por © Ideaspropias Editorial.

Una herramienta muy útil para este propósito es **Burp Suite,** una plataforma de prueba de seguridad para aplicaciones web que incluye varias funcionalidades, como un proxy para interceptar y modificar las solicitudes y respuestas HTTP/HTTPS entre el navegador y el servidor.

Ejemplo: carga de archivos

Imagina que estás realizando una prueba de penetración en una aplicación web que permite a las personas usuarias subir archivos desde sus dispositivos. Sin embargo, la aplicación no proporciona información sobre el directorio exacto donde se almacenan estos archivos en el servidor ni sobre cómo acceder a ellos una vez subidos.

Para solventar esta situación, debes utilizar la funcionalidad de carga de archivos para conseguir acceso al servidor y, así, comprometerlo. ¿Quieres averiguar cuál es el proceso para hacerlo?

- **Paso 1:** preparar un archivo PHP con una extensión que el servidor acepte. En este caso, se puede utilizar .php. El contenido del archivo debe ser una webshell que permita ejecutar comandos.
- **Paso 2:** buscar el directorio de subida y subir el archivo.
- **Paso 3:** encontrar el directorio en el servidor donde se almacenan los archivos subidos. Para ello, debemos usar herramientas de fuzzing web como Dirb o Gobuster para realizar una búsqueda exhaustiva de directorios posibles. Por ejemplo, se puede ejecutar Gobuster con un diccionario de palabras comunes para buscar carpetas como /uploads/, /files/, o /images/. Estas carpetas son lugares comunes donde las aplicaciones web suelen almacenar archivos cargados por los usuarios.
- **Paso 4:** subir el archivo utilizando el formulario de la aplicación web para shell.php (o el nombre que corresponda).
- **Paso 5:** recibir la conexión con Netcat por un puerto determinado, aunque previamente debimos haber configurado la IP y puerto de nuestra máquina atacante en la webshell de PHP. Esto nos permitirá recibir conexiones entrantes desde el servidor. Para iniciar Netcat, debemos ejecutar el siguiente comando nuestro terminal:

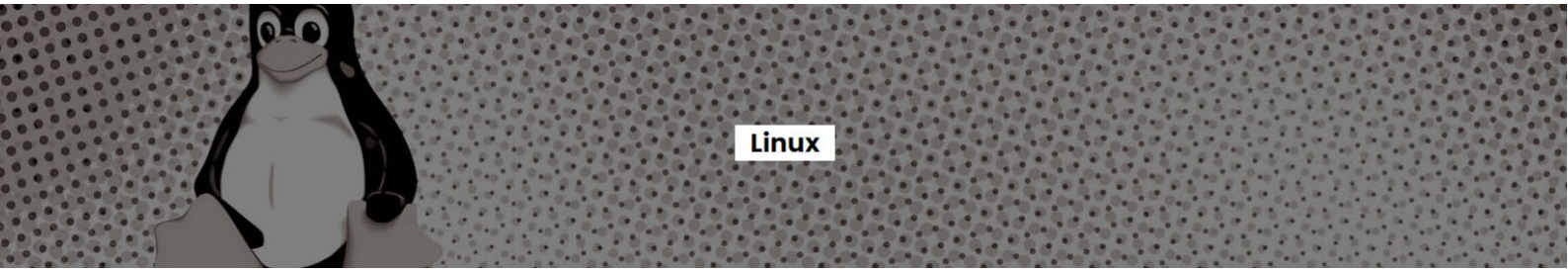
```
nc -lvnp [puerto]
```

Comandos a tener en cuenta

Llegados a este punto, es conveniente aclarar el significado de algunos de los comandos utilizados en la unidad, garantizando así un correcto entendimiento de los mismos y facilitando su posterior consulta.

No está permitida la reproducción total o parcial de este curso, ni su tratamiento informático, ni la transmisión de ninguna forma o por cualquier medio, ya sea electrónico, mecánico, por fotocopia, por registro u otros métodos, sin el permiso previo y por escrito de los titulares del Copyright.

DERECHOS RESERVADOS 2024, por © Ideaspropias Editorial.



Linux

- **sudo:** ejecutar un comando con permisos privilegiados.

Ejemplo

`sudo apt update` (actualiza la lista de paquetes con permisos de superusuario).

- **cd:** cambia el directorio actual en el que te encuentras.

Ejemplo

`cd /home/user` (cambia al directorio /home/user).

- **ifconfig:** muestra o configura las interfaces de red en un sistema.

Ejemplo

`ifconfig eth0` (muestra la configuración de la interfaz de red eth0).

- **touch:** crea un archivo desde la línea de comandos.

Ejemplo

`touch archivo.txt` (crea un archivo vacío llamado archivo.txt).

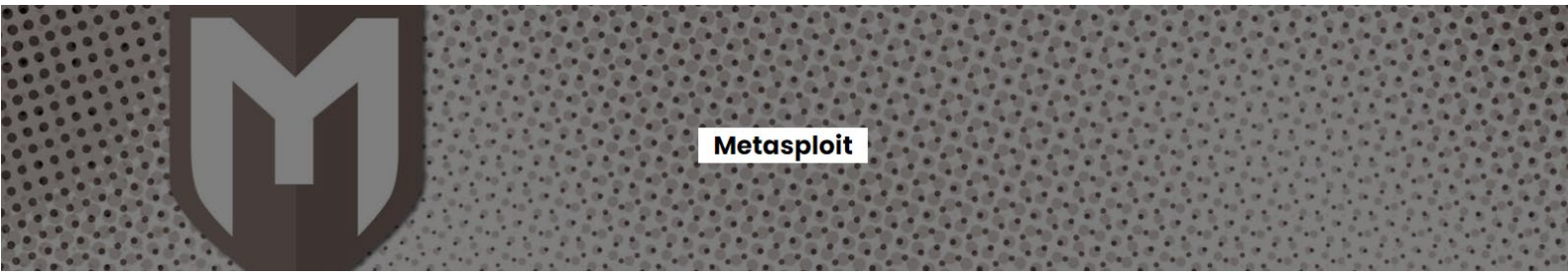
No está permitida la reproducción total o parcial de este curso, ni su tratamiento informático, ni la transmisión de ninguna forma o por cualquier medio, ya sea electrónico, mecánico, por fotocopia, por registro u otros métodos, sin el permiso previo y por escrito de los titulares del Copyright.

DERECHOS RESERVADOS 2024, por © Ideaspropias Editorial.

- **hostname -I:** muestra la dirección IP privada, sin listar ninguna otra información.

Ejemplo

`hostname -I` (muestra como salida las direcciones IP, por ejemplo, 192.168.1.100).



Metasploit

- **msfconsole:** inicia la consola de Metasploit, proporcionando una interfaz para interactuar con el framework y ejecutar diversos módulos de ataque.

Ejemplo

`msfconsole` (se ejecuta Metasploit).

- **search:** busca módulos en la base de datos de Metasploit. Es útil para localizar exploits, payloads, y otros recursos.

Ejemplo

`search exploit/windows/smb/ms17_010_eternalblue` (busca módulos)

- **set RHOSTS:** establece la dirección IP del host de destino para el módulo seleccionado en Metasploit.

No está permitida la reproducción total o parcial de este curso, ni su tratamiento informático, ni la transmisión de ninguna forma o por cualquier medio, ya sea electrónico, mecánico, por fotocopia, por registro u otros métodos, sin el permiso previo y por escrito de los titulares del Copyright.

DERECHOS RESERVADOS 2024, por © Ideaspropias Editorial.

Ejemplo

`set RHOSTS 192.168.1.10` (establece la dirección IP)

- **set LPORT:** configura el puerto local en el que el sistema escuchará para recibir conexiones entrantes del objetivo comprometido.

Ejemplo

`set LPORT 443` (indicaría que la máquina atacante estará esperando la conexión en el puerto 443)

- **run:** ejecuta el módulo cargado en Metasploit, iniciando el proceso de explotación o el payload seleccionado.

Ejemplo

`run` (se lanza el ataque desde metasploit)

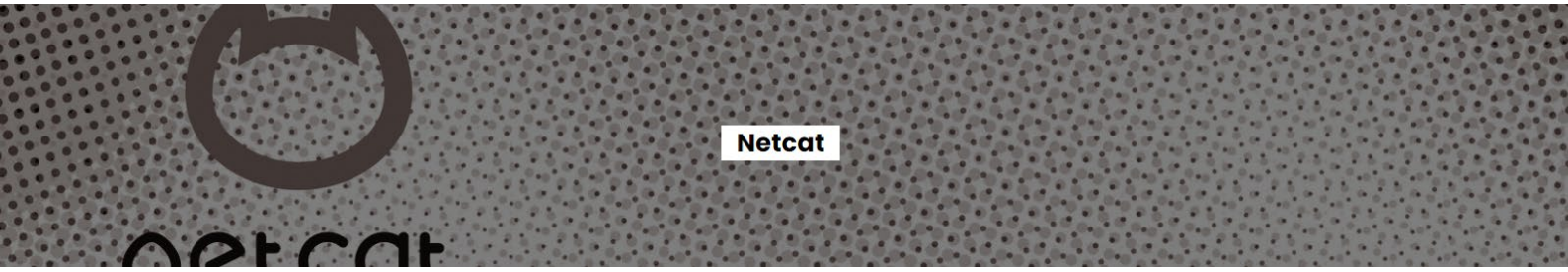
- **whoami:** muestra el nombre de usuario con el que estás actualmente logueado en el sistema.

Ejemplo

`whoami` (muestra tu nombre de usuario actual).

No está permitida la reproducción total o parcial de este curso, ni su tratamiento informático, ni la transmisión de ninguna forma o por cualquier medio, ya sea electrónico, mecánico, por fotocopia, por registro u otros métodos, sin el permiso previo y por escrito de los titulares del Copyright.

DERECHOS RESERVADOS 2024, por © Ideaspropias Editorial.



Netcat

- **nc –nlvp:** permanece a la escucha en un puerto en concreto esperando recibir una conexión o el acceso al servidor objetivo.

Ejemplo

`nc –nlvp 4444` (hace que Netcat escuche en el puerto 4444 en espera de conexiones entrantes).

No está permitida la reproducción total o parcial de este curso, ni su tratamiento informático, ni la transmisión de ninguna forma o por cualquier medio, ya sea electrónico, mecánico, por fotocopia, por registro u otros métodos, sin el permiso previo y por escrito de los titulares del Copyright.

DERECHOS RESERVADOS 2024, por © Ideaspropias Editorial.

¿QUÉ HAS APRENDIDO?

A lo largo de este bloque de contenido, has aprendido a:

- Hacer una explotación básica de vulnerabilidades mediante el uso de Metasploit o exploits disponibles por la red.
- Realizar la enumeración y explotación de vulnerabilidades básicas de una página web.
- Usar SQLmap para explotar inyecciones SQL ante formularios web.
- Enumerar detalladamente directorios, extensiones de archivos y subdominios de una web.
- Obtener una webshell para ganar acceso remoto al servidor a través de un panel de subida de archivos.

No está permitida la reproducción total o parcial de este curso, ni su tratamiento informático, ni la transmisión de ninguna forma o por cualquier medio, ya sea electrónico, mecánico, por fotocopia, por registro u otros métodos, sin el permiso previo y por escrito de los titulares del Copyright.

DERECHOS RESERVADOS 2024, por © Ideaspropias Editorial.

BIBLIOGRAFÍA

- SQLmap (s.f.). *Automatic SQL injection and database takeover tool.* Consultado el 30 de agosto de 2024.
  https://sqlmap.org/

  Recurso que proporciona información sobre SQLmap, una herramienta de código abierto utilizada para automatizar el proceso de inyección SQL y tomar el control de bases de datos. Es ampliamente utilizado en auditorías de seguridad para detectar y explotar vulnerabilidades en aplicaciones web que interactúan con bases de datos.

- PHP (2024). *Manual de PHP.*
  https://www.php.net/manual/es/index.php

  Manual oficial de PHP que sirve de referencia completa para desarrolladores web que utilizan este lenguaje de programación, ya que ofrece documentación detallada sobre las funciones, características y mejores prácticas de PHP.

No está permitida la reproducción total o parcial de este curso, ni su tratamiento informático, ni la transmisión de ninguna forma o por cualquier medio, ya sea electrónico, mecánico, por fotocopia, por registro u otros métodos, sin el permiso previo y por escrito de los titulares del Copyright.

DERECHOS RESERVADOS 2024, por © Ideaspropias Editorial.

ENLACES DE INTERÉS

- **Curso de hacking ético - qué es una reverse shell y cómo ganar acceso remoto con Netcat.**
  https://www.youtube.com/watch?v=8oGm4pEAsd8
- **Qué es y cómo utilizar SQLmap en Kali Linux | (sqli).**
  https://www.youtube.com/watch?v=A9Li1DKEzlE
- **Inyecciones SQL (4/4). Inyecciones SQL a ciegas(blind SQL); explicación y PoC.**
  https://www.curiosidadesdehackers.com/2024/08/inyecciones-sql-44-inyecciones-sql.html

FUENTES DE VÍDEO

- **Protocolos HTTP, HTTPS y DNS.**
  https://vimeo.com/1015218681?share=copy
- **Explotación automática de vulnerabilidades (Metasploit).**
  https://vimeo.com/manage/videos/1008713589
- **Explotación manual de vulnerabilidades (uso de exploits).**
  https://vimeo.com/manage/videos/1008717837
- **Enumeración de subdominios con DNSDumpster.**
  https://vimeo.com/manage/videos/1008720524
- **Enumeración de subdominios con Wfuzz.**
  https://vimeo.com/manage/videos/1008723142
- **Explotación básica con inyecciones SQL.**
  https://vimeo.com/manage/videos/1008727774
- **Explotación automática con inyecciones SQL.**
  https://vimeo.com/manage/videos/1008729571
- **Creación de una webshell (Parte 1).**
  https://vimeo.com/manage/videos/1008734367
- **Creación de una webshell (Parte 2).**
  https://vimeo.com/manage/videos/1008736894

No está permitida la reproducción total o parcial de este curso, ni su tratamiento informático, ni la transmisión de ninguna forma o por cualquier medio, ya sea electrónico, mecánico, por fotocopia, por registro u otros métodos, sin el permiso previo y por escrito de los titulares del Copyright.

DERECHOS RESERVADOS 2024, por © Ideaspropias Editorial.

PREGUNTAS FRECUENTES

- **¿Qué es una *reverse shell*?**
  Una reverse shell es un tipo de shell, que se establece desde un sistema comprometido hacia un sistema atacante, a través de una conexión de red. En lugar de que el atacante se conecte directamente al sistema objetivo para obtener acceso, el sistema comprometido inicia la conexión hacia el atacante, permitiendo al atacante tomar control del sistema de manera remota.

  En una reverse shell, el objetivo ejecuta un comando en el sistema comprometido que se conecta a una dirección IP y un puerto, controlados por el atacante. Una vez establecida la conexión, el atacante puede enviar comandos al sistema comprometido y recibir la salida, actuando como si estuviera trabajando directamente en la máquina comprometida.

  Este tipo de shell es común en ataques de hacking y pruebas de penetración porque puede eludir algunos mecanismos de defensa, como cortafuegos (*firewalls*) y sistemas de detección de intrusiones, que están configurados para bloquear conexiones entrantes.

- **¿Qué diferencia hay entre un servidor DNS y un registro DNS?**
  Un servidor DNS es el protocolo que se encarga de traducir nombres de dominio legibles por humanos, como «example.com», en direcciones IP que los dispositivos utilizan para comunicarse entre sí.

  Por otro lado, un registro DNS es una entrada específica que define cómo se deben manejar diferentes aspectos de un dominio. Por ejemplo, un registro puede asignar una dirección IP a un nombre de dominio, mientras que otro registro puede especificar qué servidor de correo debe recibir los emails para ese dominio. Cada tipo de registro tiene una función diferente para gestionar la información relacionada con el dominio.

No está permitida la reproducción total o parcial de este curso, ni su tratamiento informático, ni la transmisión de ninguna forma o por cualquier medio, ya sea electrónico, mecánico, por fotocopia, por registro u otros métodos, sin el permiso previo y por escrito de los titulares del Copyright.

DERECHOS RESERVADOS 2024, por © Ideaspropias Editorial.

GLOSARIO

A

- **Auto_deploy**
  Script que se utiliza para desplegar de forma automática laboratorios vulnerables de la plataforma de dockerlabs.es

B

- **Backend**
  Parte de una aplicación web o sistema que gestiona la lógica del servidor, el procesamiento de datos y la comunicación con bases de datos.
- **Base de datos**
  Conjunto de datos organizados y estructurados que se almacenan y gestionan de manera que puedan ser fácilmente accedidos, gestionados y actualizados.
- **Bypass**
  Técnica utilizada para eludir las restricciones de seguridad del panel de login, que se logra manipulando las consultas SQL enviadas al servidor, para conseguir acceso no autorizado o eludir la autenticación
- **Bash**
  Intérprete de que se utiliza en sistemas Linux para ejecutar comandos.

D

- **DNS**
  Protocolo que traduce nombres de dominio en direcciones IP, que son números que identifican de manera única a los dispositivos en una red.
- **Dirb**
  Herramienta utilizada en hacking web para conocer carpetas o archivos existentes dentro de un servidor web.

E

- **Exploit**
  Código o técnica que aprovecha una vulnerabilidad en un software o sistema para obtener acceso no autorizado o realizar acciones maliciosas.

M

- **Malware**
  Software malicioso diseñado para dañar, infiltrarse o robar información en un sistema sin el consentimiento del usuario.

N

- **Nano**
  Editor de texto sencillo que se usa en la terminal de Linux.

No está permitida la reproducción total o parcial de este curso, ni su tratamiento informático, ni la transmisión de ninguna forma o por cualquier medio, ya sea electrónico, mecánico, por fotocopia, por registro u otros métodos, sin el permiso previo y por escrito de los titulares del Copyright.

DERECHOS RESERVADOS 2024, por © Ideaspropias Editorial.

- **Netcat**
  Herramienta de red que permite establecer conexiones de red tanto para la transmisión como para la recepción de datos.

- **Nmap**
  Herramienta para realizar un escaneo de puertos de un objetivo, así como lanzar distintos tipos de ataques.

P

- **Panel de login**
  Interfaz de usuario en un sitio web o aplicación que permite a los usuarios ingresar sus credenciales, como nombre de usuario y contraseña, para acceder a áreas restringidas del sistema. Suele ser una de las primeras puertas de entrada a la funcionalidad protegida de una aplicación.

- **Payloads**
  Carga útil que se ejecuta tras la explotación.

- **PHP**
  Lenguaje de programación que se ejecuta en el lado del servidor, ampliamente utilizado para desarrollar aplicaciones web dinámicas y gestionar contenido web.

- **Python**
  Lenguaje de programación de alto nivel, interpretado y de propósito general, ampliamente utilizado en desarrollo web, análisis de datos, inteligencia artificial, automatización y más, debido a su versatilidad y a la gran cantidad de bibliotecas y frameworks disponibles.

R

- **Registro DNS**
  Entrada en la base de datos del sistema de nombres de dominio (DNS) que asocia un nombre de dominio con información específica sobre ese dominio. Existen varios tipos de registros DNS, cada uno con una función diferente.

S

- **Script**
  Conjunto de instrucciones o código escrito en un lenguaje de programación que se ejecuta automáticamente para realizar tareas específicas.

- **SQL**
  Lenguaje de consulta estructurado utilizado para gestionar y manipular bases de datos relacionales.

W

- **Wordlist**
  Archivo que contiene una lista de palabras o términos que se utilizan para realizar pruebas automatizadas en ataques de fuerza bruta, enumeración de directorios o subdominios, entre otros.

No está permitida la reproducción total o parcial de este curso, ni su tratamiento informático, ni la transmisión de ninguna forma o por cualquier medio, ya sea electrónico, mecánico, por fotocopia, por registro u otros métodos, sin el permiso previo y por escrito de los titulares del Copyright.

DERECHOS RESERVADOS 2024, por © Ideaspropias Editorial.

CRÉDITOS DE PRODUCCIÓN

Los iconos e imágenes que ilustran este curso han sido diseñados originalmente por unsplash.com, flaticon.com y freepik.com.

Algunos comentarios bibliográficos incluidos en esta unidad didáctica han sido generados con ChatGPT de OpenAI, un avanzado modelo de lenguaje basado en la arquitectura GPT-4.

No está permitida la reproducción total o parcial de este curso, ni su tratamiento informático, ni la transmisión de ninguna forma o por cualquier medio, ya sea electrónico, mecánico, por fotocopia, por registro u otros métodos, sin el permiso previo y por escrito de los titulares del Copyright.

DERECHOS RESERVADOS 2024, por © Ideaspropias Editorial.

IDEASPROPIAS
editorial